

ENCUESTA INTEGRAL DE CIBERSEGURIDAD (CRM 2024-2025)

Kit Profesional de Evaluación — Modelo de Cuestionario Completo

Versión: 2.0 | **Fecha:** Enero 2026 | **Autor:** Consorcio Experto CRM | **Clasificación:** Público

INTRODUCCIÓN Y PROPÓSITO

Esta encuesta integral evalúa la madurez de Cyber Risk Management (CRM) en su organización, abarcando:

- ✓ Gobernanza estratégica (Risk Appetite, NIST CSF 2.0 Govern)
- ✓ Cuantificación monetaria (FAIR framework, ALE)
- ✓ Threat modeling operacional (PASTA)
- ✓ Métricas y KPIs (MTTD/MTTR, SIEM, SOC)
- ✓ Compliance regulatorio (GDPR, DORA, NIS2)
- ✓ Capacitación seguridad (Awareness training, phishing ROI)
- ✓ Automatización (Policy-as-Code, Chaos Engineering)

Tiempo estimado: 45-60 minutos | **Audiencia:** CISO, IT Manager, Risk Officer, Junta Directiva

SECCIÓN 1: GOBERNANZA ESTRATÉGICA Y LIDERAZGO

1.1 — Risk Appetite Statement (RAS) & Governance

Pregunta 1.1.1: ¿Tiene su organización un documento formalizado de "Risk Appetite Statement" (declaración de apetito de riesgo) en ciberseguridad?

- ☐ A) Sí, documentado y aprobado junta directiva en últimos 12 meses

Evidencia: Documento firmado, distribuido stakeholders, revisión anual

- ☐ B) Sí, documentado pero sin revisión reciente (>12 meses)

Riesgo: Obsoleto; no refleja entorno amenaza actual

- ☐ C) Existe, pero es informal (conversaciones, no documentado)

Debilidad: Falta claridad, comunicación inconsistente

- ☐ D) No existe; decisiones riesgo son ad-hoc

- Crítico: No alignment gobernanza; decisiones reactivas

Evidencia: Documento firmado, distribuido stakeholders, revisión anual

- ☐ **B) Sí, documentado pero sin revisión reciente (>12 meses)**

Riesgo: Obsoleto; no refleja entorno amenaza actual

- ☐ **C) Existe, pero es informal (conversaciones, no documentado)**

Debilidad: Falta claridad, comunicación inconsistente

- ☐ **D) No existe; decisiones riesgo son ad-hoc**

Pregunta 1.1.2: ¿Tiene su organización definidas "Risk Tolerance Levels" operacionales para dominios específicos (ej: downtime, phishing click rate, breach data)?

- ☐ A) Sí, con umbrales cuantitativos claros (ej: MTTD <2h, phishing <5% click)

•

Excelencia: Métricas específicas; escalación automática si superan

•

- ☐ B) Sí, pero solo para algunos dominios (ej: finanzas, pero no email)

•

Parcial: Cobertura incompleta

•

- ☐ C) Existen límites informales; no documentados globalmente

•

Debilidad: Inconsistencia entre equipos

•

- ☐ D) No existen; no hay umbrales formales

- Crítico: Sin guardrails operacionales

Excelencia: Métricas específicas; escalación automática si superan

- ☐ B) **Sí, pero solo para algunos dominios (ej: finanzas, pero no email)**

Parcial: Cobertura incompleta

- ☐ C) **Existen límites informales; no documentados globalmente**

Debilidad: Inconsistencia entre equipos

- ☐ D) **No existen; no hay umbrales formales**

Pregunta 1.1.3: ¿Con qué frecuencia la Junta Directiva (o Comité Riesgo) recibe información sobre postura ciberseguridad?

- ☐ A) Mensual o más frecuente, con dashboards específicos
- Óptimo: Visibilidad ejecutiva alta
- ☐ B) Trimestral, mediante reportes formales
- Aceptable: Cadencia regulatoria típica
- ☐ C) Anual o ad-hoc (solo si incidente)
- Débil: Falta visibilidad estratégica
- ☐ D) Raramente o nunca; seguridad es responsabilidad solo IT
- Crítico: Desconexión junta-seguridad

Óptimo: Visibilidad ejecutiva alta

☐ **B) Trimestral, mediante reportes formales**

Aceptable: Cadencia regulatoria típica

☐ **C) Anual o ad-hoc (solo si incidente)**

Débil: Falta visibilidad estratégica

☐ **D) Raramente o nunca; seguridad es responsabilidad solo IT**

1.2 — NIST CSF 2.0 Govern Function Implementation

Pregunta 1.2.1: ¿Ha mapeado su organización su actual seguridad posture contra NIST Cybersecurity Framework 2.0 Govern function (nueva en feb 2024)?

- ☐ A) Sí, mapeo completo (GV.OC, GV.RM, GV.RH, GV.SC, GV.OP)

•

Avanzado: Implementación estructurada

•

- ☐ B) Sí, mapeo parcial (3-4 categorías de Govern)

•

Implementación: En progreso

•

- ☐ C) No, pero están planeando (roadmap <12 meses)

•

Consciente del requerimiento; timeline indefinido

•

- ☐ D) No; no es prioridad actualmente

- Riesgo: NIS2 requiere esto; compliance gap

Avanzado: Implementación estructurada

- ☐ **B) Sí, mapeo parcial (3-4 categorías de Govern)**

Implementación: En progreso

- ☐ **C) No, pero están planeando (roadmap <12 meses)**

Consciente del requerimiento; timeline indefinido

- ☐ **D) No; no es prioridad actualmente**

Pregunta 1.2.2: ¿Tiene designado formalmente un CISO o "responsable ciberseguridad" con acceso directo a dirección/junta?

- ☐ A) Sí, CISO en C-suite; reporta directamente CEO/Presidente

• Óptimo: Accountability en nivel estratégico

- ☐ B) Sí, responsable seguridad designado; reporta CIO o COO

• Aceptable: Línea reporting formada

- ☐ C) Sí, pero sin línea reporting clara; depende contexto

• Débil: Autoridad ambigua

- ☐ D) No existe rol formalizado; responsabilidades dispersas

- Crítico: NIST 2.0 y NIS2 exigen designación

Óptimo: Accountability en nivel estratégico

- ☐ B) **Sí, responsable seguridad designado; reporta CIO o COO**

Aceptable: Línea reporting formada

- ☐ C) **Sí, pero sin línea reporting clara; depende contexto**

Débil: Autoridad ambigua

- ☐ D) **No existe rol formalizado; responsabilidades dispersas**

SECCIÓN 2: CUANTIFICACIÓN DE RIESGOS — FAIR FRAMEWORK

2.1 — Metodología Cuantificación Riesgo

Pregunta 2.1.1: ¿Utiliza su organización un framework cuantitativo para evaluar riesgos cibernéticos en términos monetarios (€/ \$ ALE)?

- ☐ A) Sí, FAIR framework implementado ($LEF \times LM = ALE$)

-

Avanzado: Cuantificación monetaria robusta

-

- ☐ B) Sí, otro framework cuantitativo (ej: CRIM, CREAM)

-

Alternativo: Metodología monetaria

-

- ☐ C) Matriz cualitativa (Alto/Medio/Bajo) sin monetización

-

Tradicional: Limitaciones para decisiones inversión

-

- ☐ D) No; evaluación principalmente ad-hoc

- Débil: Falta rigor cuantitativo

Avanzado: Cuantificación monetaria robusta

- ☐ B) Sí, otro framework cuantitativo (ej: CRIM, CREAM)

Alternativo: Metodología monetaria

- ☐ C) Matriz cualitativa (Alto/Medio/Bajo) sin monetización

Tradicional: Limitaciones para decisiones inversión

- ☐ D) No; evaluación principalmente ad-hoc

Pregunta 2.1.2: Para sus top 5 riesgos cibernéticos, ¿conoce el impacto financiero estimado (ALE anual)?

- ☐ A) Sí, todos los top 5 riesgos cuantificados; reportado a junta

•

Excelencia: Visibilidad financiera clara

•

- ☐ B) Sí, 3-4 de los top 5 riesgos cuantificados

•

Parcial: Cobertura incompleta

•

- ☐ C) Sí, pero estimates son imprecisas (rango muy amplio)

•

Débil: Precisión insuficiente para decisiones

•

- ☐ D) No; no se ha cuantificado

- **Crítico: Imposible justificar inversiones ante CFO**

Excelencia: Visibilidad financiera clara

- ☐ **B) Sí, 3-4 de los top 5 riesgos cuantificados**

Parcial: Cobertura incompleta

- ☐ **C) Sí, pero estimates son imprecisas (rango muy amplio)**

Débil: Precisión insuficiente para decisiones

- ☐ **D) No; no se ha cuantificado**

Pregunta 2.1.3: ¿Realiza su organización análisis ROI explícito para decisiones control/mitigación (ej: "invertir €100K en EDR reduce ALE €5M – ROI 50:1")?

- ☐ A) Sí, rutinariamente; ROI es criterio aprobación controles
- Óptimo: Inversiones justificadas por ROI
- ☐ B) Sí, ocasionalmente para proyectos mayores
- Ocasional: Utilización selectiva
- ☐ C) Raramente; decisiones basadas en "benchmarking" vs competencia
- Débil: ROI no es criterio principal
- ☐ D) Nunca; presupuesto asignado por porcentaje histórico
- Crítico: Falta optimización inversión

Óptimo: Inversiones justificadas por ROI

☐ **B) Sí, ocasionalmente para proyectos mayores**

Ocasional: Utilización selectiva

☐ **C) Raramente; decisiones basadas en "benchmarking" vs competencia**

Débil: ROI no es criterio principal

☐ **D) Nunca; presupuesto asignado por porcentaje histórico**

SECCIÓN 3: THREAT MODELING OPERACIONAL — PASTA

3.1 — Threat Modeling Methodology

Pregunta 3.1.1: ¿Realiza su organización threat modeling formal (ej: PASTA, STRIDE) para aplicaciones/sistemas críticos?

- ☐ A) Sí, PASTA o similar para 100% sistemas críticos; actualizado anual

-

Avanzado: Cobertura completa, iterativo

-

- ☐ B) Sí, para 50-75% sistemas críticos

-

Implementación: Cobertura parcial

-

- ☐ C) Sí, pero ad-hoc; no sistematizado ni documentado

-

Débil: Falta rigurosidad

-

- ☐ D) No; no realiza threat modeling formal

- Crítico: Riesgo de vulnerabilidades no identificadas

Avanzado: Cobertura completa, iterativo

- ☐ **B) Sí, para 50-75% sistemas críticos**

Implementación: Cobertura parcial

- ☐ **C) Sí, pero ad-hoc; no sistematizado ni documentado**

Débil: Falta rigurosidad

- ☐ **D) No; no realiza threat modeling formal**

Pregunta 3.1.2: En threat modeling, ¿llega hasta crear "attack trees" con probabilidades de éxito estimadas?

- ☐ A) Sí, attack trees completos con PoC (proof-of-concept) y probabilidades

•

Excelencia: Detalle operacional alto

•

- ☐ B) Sí, attack trees básicos sin probabilidades

•

Implementación: Estructura sin cuantificación

•

- ☐ C) Identifica amenazas, pero no construye árboles

•

Básico: Falta modelado de ataque

•

- ☐ D) No; no llega a análisis de ataque

- Débil: Comprensión limitada viabilidad

Excelencia: Detalle operacional alto

- ☐ **B) Sí, attack trees básicos sin probabilidades**

Implementación: Estructura sin cuantificación

- ☐ **C) Identifica amenazas, pero no construye árboles**

Básico: Falta modelado de ataque

- ☐ **D) No; no llega a análisis de ataque**

Pregunta 3.1.3: ¿Mapea sistemáticamente las amenazas identificadas a vulnerabilidades reales (CWE, CVE) encontradas en pentesting/SAST?

- ☐ A) Sí, mapeo trazable documentado; correlación threat-vuln clara

•

Óptimo: Validación teórica ↔ práctica

•

- ☐ B) Sí, parcialmente; algunos mappings realizados

•

Parcial: Correlación selectiva

•

- ☐ C) A veces; depende del proyecto

•

Inconsistente: Falta sistematización

•

- ☐ D) No; amenazas y vulnerabilidades son análisis separados

- Débil: Falta integración

Óptimo: Validación teórica ↔ práctica

- ☐ **B) Sí, parcialmente; algunos mappings realizados**

Parcial: Correlación selectiva

- ☐ **C) A veces; depende del proyecto**

Inconsistente: Falta sistematización

- ☐ **D) No; amenazas y vulnerabilidades son análisis separados**

SECCIÓN 4: MÉTRICAS OPERACIONALES Y SOC/SIEM

4.1 — SOC Capabilities & MTTD/MTTR

Pregunta 4.1.1: ¿Tiene su organización un Security Operations Center (SOC) operativo 24/7?

- ☐ A) Sí, SOC interno 24/7/365 con equipo dedicado

•

Óptimo: Cobertura máxima

•

- ☐ B) Sí, SOCaaS (outsourcado) 24/7

•

Equivalente: Cobertura tercero

•

- ☐ C) SOC parcial (ej: 12h, o 24h solo financiero)

•

Limitado: Cobertura parcial

•

- ☐ D) No; monitoreo ad-hoc sin SOC formalizado

- Crítico: Cobertura insuficiente

Óptimo: Cobertura máxima

- ☐ **B) Sí, SOCaaS (outsourcado) 24/7**

Equivalente: Cobertura tercero

- ☐ **C) SOC parcial (ej: 12h, o 24h solo financiero)**

Limitado: Cobertura parcial

- ☐ **D) No; monitoreo ad-hoc sin SOC formalizado**

Pregunta 4.1.2: ¿Cuál es su MTTD (Mean Time To Detect) incidentes cibernéticos?

- ☐ A) <30 minutos (industria best practice: 30 min - 4 horas)

•

Excelente: Detección rápida

•

☐ B) 30 min - 4 horas

•

Bueno: Benchmark acceptable

•

☐ C) 4 - 24 horas

•

Medio: Tiempo relevante; hay margen mejora

•

☐ D) >24 horas o desconocido

- Débil: Falta visibilidad

Excelente: Detección rápida

☐ **B) 30 min - 4 horas**

Bueno: Benchmark acceptable

☐ **C) 4 - 24 horas**

Medio: Tiempo relevante; hay margen mejora

☐ **D) >24 horas o desconocido**

Pregunta 4.1.3: ¿Cuál es su MTTR (Mean Time To Respond/Recover) incidentes críticos?

- ☐ A) <4 horas (target DORA financiero)

•

Excelente: RTO agresivo

•

☐ B) 4 - 24 horas

•

Bueno: Cumple objetivos*

•

☐ C) 24 - 72 horas

•

Medio: Oportunidad mejora

•

☐ D) >72 horas o desconocido

- Crítico: Tiempos inaceptables

Excelente: RTO agresivo

☐ **B) 4 - 24 horas**

*Bueno: Cumple objetivos**

☐ **C) 24 - 72 horas**

Medio: Oportunidad mejora

☐ **D) >72 horas o desconocido**

4.2 — SIEM Capabilities & Alerting

Pregunta 4.2.1: ¿Tiene implementado un SIEM (Security Information & Event Management)?

- ☐ A) Sí, SIEM enterprise (ej: Splunk, Elastic) + SOAR integration

•

Avanzado: Stack completo

•

- ☐ B) Sí, SIEM funcional pero sin SOAR

•

Implementado: Cobertura base

•

- ☐ C) SIEM básico; limitaciones en escala o correlación

•

Limitado: Capacidad reducida

•

- ☐ D) No tiene SIEM formalizado

- Crítico: Visibilidad muy limitada

Avanzado: Stack completo

- ☐ **B) Sí, SIEM funcional pero sin SOAR**

Implementado: Cobertura base

- ☐ **C) SIEM básico; limitaciones en escala o correlación**

Limitado: Capacidad reducida

- ☐ **D) No tiene SIEM formalizado**

Pregunta 4.2.2: ¿Cuántas fuentes de log alimentan su SIEM?

- ☐ A) >50 fuentes (firewall, endpoint, cloud, aplicaciones)

-

Completo: Visibilidad amplia

-

☐ B) 20-50 fuentes

-

Bueno: Cobertura significativa

-

☐ C) 5-20 fuentes

-

Básico: Cobertura limitada

-

☐ D) <5 fuentes

- Muy limitado: Gaps en cobertura

Completo: Visibilidad amplia

☐ **B) 20-50 fuentes**

Bueno: Cobertura significativa

☐ **C) 5-20 fuentes**

Básico: Cobertura limitada

☐ **D) <5 fuentes**

Pregunta 4.2.3: ¿Cuál es su "Alert Fatigue" (False Positive Rate)?

- ☐ A) <5% falsos positivos (industria best: <5%)

•

Excelente: Ruido bajo

•

☐ B) 5-10%

•

Bueno: Tolerable

•

☐ C) 10-25%

•

Medio: Causa desgaste analistas

•

☐ D) >25% o desconocido

- Crítico: Alert fatigue severo

Excelente: Ruido bajo

☐ **B) 5-10%**

Bueno: Tolerable

☐ **C) 10-25%**

Medio: Causa desgaste analistas

☐ **D) >25% o desconocido**

Pregunta 4.2.4: ¿Qué porcentaje de alertas SIEM son automatizadas (playbooks SOAR)?

- ☐ A) >70% respuesta automática
- Avanzado: Alta automatización
- ☐ B) 40-70% automatizado
- Implementado: Automatización significativa
- ☐ C) 10-40% automatizado
- Parcial: Oportunidad mejora
- ☐ D) <10% o sin automatización

- Débil: Dependencia manual

Avanzado: Alta automatización

☐ **B) 40-70% automatizado**

Implementado: Automatización significativa

☐ **C) 10-40% automatizado**

Parcial: Oportunidad mejora

☐ **D) <10% o sin automatización**

SECCIÓN 5: VULNERABILITIES & VULNERABILITY MANAGEMENT

5.1 — Vulnerability Assessment & Patching

Pregunta 5.1.1: ¿Realiza escaneo de vulnerabilidades automático?

- ☐ A) Sí, continuo (diario mínimo) en todos los sistemas
- Óptimo: Cobertura y frecuencia máxima
- ☐ B) Sí, semanal en sistemas críticos; menor frecuencia en no-críticos
- Bueno: Cadencia diferenciada
- ☐ C) Mensual o ad-hoc
- Débil: Frecuencia insuficiente
- ☐ D) Raramente o no formalizado

- Crítico: Visibilidad vulnerabilidades muy baja

Óptimo: Cobertura y frecuencia máxima

☐ **B) Sí, semanal en sistemas críticos; menor frecuencia en no-críticos**

Bueno: Cadencia diferenciada

☐ **C) Mensual o ad-hoc**

Débil: Frecuencia insuficiente

☐ **D) Raramente o no formalizado**

Pregunta 5.1.2: ¿Cuál es su tiempo promedio de parcheo para vulnerabilidades críticas (CVSS 9-10)?

- ☐ A) <7 días (30% de organizaciones)
- Excelente: Remediación rápida
- ☐ B) 7-30 días
- Bueno: Cumple estándares (ISO 27001, NIS2)
- ☐ C) 30-90 días
- Medio: Margen de riesgo
- ☐ D) >90 días o sin SLA formal
- Crítico: Ventana exposición inaceptable

Excelente: Remediación rápida

☐ **B) 7-30 días**

Bueno: Cumple estándares (ISO 27001, NIS2)

☐ **C) 30-90 días**

Medio: Margen de riesgo

☐ **D) >90 días o sin SLA formal**

Pregunta 5.1.3: ¿Utiliza CVSS v4.0 (lanzado junio 2024) para priorización vulnerabilidades?

- ☐ A) Sí, CVSS v4.0 + EPSS (Exploit Prediction) para priorización

•

Avanzado: Scoring dual (impact + likelihood)

•

- ☐ B) Sí, CVSS v4.0 solo

•

Implementado: Versión actual

•

- ☐ C) CVSS v3.1 (versión anterior)

•

Obsoleto: Migración recomendada 2026

•

- ☐ D) No utiliza CVSS sistemáticamente

- Débil: Sin framework priorización

Avanzado: Scoring dual (impact + likelihood)

- ☐ **B) Sí, CVSS v4.0 solo**

Implementado: Versión actual

- ☐ **C) CVSS v3.1 (versión anterior)**

Obsoleto: Migración recomendada 2026

- ☐ **D) No utiliza CVSS sistemáticamente**

5.2 — Vulnerability Lifecycle Management

Pregunta 5.2.1: ¿Tiene documentado un "SLA de Remediación Vulnerabilidades" por severidad (ej: crítica <7d, alta <30d)?

- ☐ A) Sí, SLAs diferenciados por severidad CVSS + EPSS

•

Óptimo: Priorización data-driven

•

- ☐ B) Sí, SLAs básicos (crítica, alta, media, baja)

•

Implementado: Cadencia clara

•

- ☐ C) SLAs informales; depende contexto

•

Débil: Falta rigor

•

- ☐ D) No existen SLAs formales

- Crítico: Sin accountability remediación

Óptimo: Priorización data-driven

- ☐ **B) Sí, SLAs básicos (crítica, alta, media, baja)**

Implementado: Cadencia clara

- ☐ **C) SLAs informales; depende contexto**

Débil: Falta rigor

- ☐ **D) No existen SLAs formales**

Pregunta 5.2.2: ¿Implementa "Risk-Based Remediation" (acepta cierto riesgo residual documentado)?

- ☐ A) Sí, formal; documentado qué vulns se aceptan + justificación riesgo

-

Maduro: Risk-aware approach

-

- ☐ B) Sí, parcialmente; algunos riesgos aceptados informalmente

-

Pragmático: Aceptación ad-hoc

-

- ☐ C) No; intenta parchear todo (unrealistic)

-

Idealista: Puede causar fatiga

-

- ☐ D) No hay proceso formal; falta visibility

- Débil: Falta control

Maduro: Risk-aware approach

- ☐ **B) Sí, parcialmente; algunos riesgos aceptados informalmente**

Pragmático: Aceptación ad-hoc

- ☐ **C) No; intenta parchear todo (unrealistic)**

Idealista: Puede causar fatiga

- ☐ **D) No hay proceso formal; falta visibility**

SECCIÓN 6: SEGURIDAD SUPPLY CHAIN Y TERCEROS

6.1 — Third-Party Risk Management (Vendor Risk)

Pregunta 6.1.1: ¿Realiza auditoría de seguridad (ciberseguridad) a proveedores/terceros críticos?

- ☐ A) Sí, auditoría formal anual mínimo; incluye ISO 27001 o SOC2

•

Óptimo: Rigor de cumplimiento

•

- ☐ B) Sí, auditoría anual; menos rigurosa

•

Implementado: Cobertura anual

•

- ☐ C) Ad-hoc; solo para ciertos proveedores

•

Parcial: Cobertura inconsistente

•

- ☐ D) Raramente o no; confía en vendor self-reporting

- Crítico: Riesgo supply chain muy alto

Óptimo: Rigor de cumplimiento

- ☐ **B) Sí, auditoría anual; menos rigurosa**

Implementado: Cobertura anual

- ☐ **C) Ad-hoc; solo para ciertos proveedores**

Parcial: Cobertura inconsistente

- ☐ **D) Raramente o no; confía en vendor self-reporting**

Pregunta 6.1.2: ¿Incluye requisitos ciberseguridad explícitos en contratos terceros (SLA, MFA, encryption, incident reporting)?

- ☐ A) Sí, cláusulas técnicas detalladas + derechos auditoría

•

Óptimo: Contractual enforcement

•

- ☐ B) Sí, cláusulas básicas presentes

•

Implementado: Cobertura base

•

- ☐ C) Parcialmente; algunos proveedores, no todos

•

Inconsistente: Gap contractual

•

- ☐ D) No; sin requisitos de ciberseguridad en contrato

- Crítico: Sin leverage legal

Óptimo: Contractual enforcement

- ☐ **B) Sí, cláusulas básicas presentes**

Implementado: Cobertura base

- ☐ **C) Parcialmente; algunos proveedores, no todos**

Inconsistente: Gap contractual

- ☐ **D) No; sin requisitos de ciberseguridad en contrato**

Pregunta 6.1.3: ¿Mantiene SBOM (Software Bill of Materials) para software/dependencias críticos?

- ☐ A) Sí, SBOM documentado (SPDX format); actualizado con cambios
-

Avanzado: Visibilidad supply chain

- ☐ B) Sí, SBOM existente pero no siempre actualizado
-

Implementado: Cobertura base

- ☐ C) Parcial; solo para proyectos nuevos
-

Emergente: Adopción en progreso

- ☐ D) No; no mantiene SBOM formal

- **Crítico: Riesgo dependency vulnerabilities muy alto**

Avanzado: Visibilidad supply chain

- ☐ **B) Sí, SBOM existente pero no siempre actualizado**

Implementado: Cobertura base

- ☐ **C) Parcial; solo para proyectos nuevos**

Emergente: Adopción en progreso

- ☐ **D) No; no mantiene SBOM formal**

SECCIÓN 7: CAPACITACIÓN SEGURIDAD & AWARENESS

7.1 — Security Awareness Training Program

Pregunta 7.1.1: ¿Realiza entrenamiento de ciberseguridad obligatorio para todos los empleados?

- ☐ A) Sí, training inicial + refresher anual mínimo (100% cumplimiento)

•

Óptimo: Cobertura universal

•

- ☐ B) Sí, anual para 80-99% empleados

•

Bueno: Cobertura alta

•

- ☐ C) Sí, anual pero cumplimiento 50-80%

•

Medio: Gaps significativos

•

- ☐ D) No formalizado u opcional

- Crítico: Falta rigor mandatorio

Óptimo: Cobertura universal

- ☐ **B) Sí, anual para 80-99% empleados**

Bueno: Cobertura alta

- ☐ **C) Sí, anual pero cumplimiento 50-80%**

Medio: Gaps significativos

- ☐ **D) No formalizado u opcional**

Pregunta 7.1.2: ¿Incluye phishing simulation campaigns como parte de awareness program?

- ☐ A) Sí, monthly simulations + targeted training para clickers

•

Avanzado: Frecuencia y follow-up

•

- ☐ B) Sí, quarterly simulations

•

Implementado: Cadencia aceptable

•

- ☐ C) Ad-hoc; 1-2 campaigns/año

•

Débil: Frecuencia insuficiente

•

- ☐ D) No realiza phishing simulations

- Crítico: Sin validación comportamiento

Avanzado: Frecuencia y follow-up

- ☐ **B) Sí, quarterly simulations**

Implementado: Cadencia aceptable

- ☐ **C) Ad-hoc; 1-2 campaigns/año**

Débil: Frecuencia insuficiente

- ☐ **D) No realiza phishing simulations**

Pregunta 7.1.3: ¿Cuál es su actual "Phishing Click Rate" (% empleados que hacen click)?

- ☐ A) <3% (mejor industria)
- Excelente: Comportamiento seguro
- ☐ B) 3-5%
- Bueno: Aceptable
- ☐ C) 5-10%
- Medio: Oportunidad mejora
- ☐ D) >10% o desconocido
- Débil: Riesgo elevado

Excelente: Comportamiento seguro

☐ **B) 3-5%**

Bueno: Aceptable

☐ **C) 5-10%**

Medio: Oportunidad mejora

☐ **D) >10% o desconocido**

Pregunta 7.1.4: ¿Cuál es su "Phishing Reporting Rate" (% emails reportados como sospechosos)?

- ☐ A) >20% (empleados activamente reportan amenazas)

-

Excelente: Cultura engagement

-

☐ B) 10-20%

-

Bueno: Participación significativa

-

☐ C) 5-10%

-

Medio: Participación moderada

-

☐ D) <5% o desconocido

- Débil: Falta de engagement

Excelente: Cultura engagement

☐ **B) 10-20%**

Bueno: Participación significativa

☐ **C) 5-10%**

Medio: Participación moderada

☐ **D) <5% o desconocido**

7.2 — Security Awareness ROI & Metrics

Pregunta 7.2.1: ¿Calcula y reporta el ROI de su programa de awareness training?

- ☐ A) Sí, formal; monetiza avoided losses vs training cost
- Óptimo: Business case cuantificado
- ☐ B) Sí, parcialmente; usa métricas comportamiento pero sin \$
- Parcial: Métricas sin monetización
- ☐ C) Raramente; no sistemático
- Débil: Falta rigor
- ☐ D) No; training es "cost center" sin ROI
- Crítico: Sin justificación inversión

Óptimo: Business case cuantificado

☐ **B) Sí, parcialmente; usa métricas comportamiento pero sin \$**

Parcial: Métricas sin monetización

☐ **C) Raramente; no sistemático**

Débil: Falta rigor

☐ **D) No; training es "cost center" sin ROI**

Pregunta 7.2.2: ¿Cuál es la métrica de satisfacción/engagement empleados con training?

- ☐ A) >4.0/5.0 (training relevante, engaging)

•

Excelente: Alto engagement

•

☐ B) 3.5-4.0

•

Bueno: Satisfacción aceptable

•

☐ C) 3.0-3.5

•

Medio: Hay insatisfacción

•

☐ D) <3.0 o no medido

- Débil: Contenido no resonante

Excelente: Alto engagement

☐ **B) 3.5-4.0**

Bueno: Satisfacción aceptable

☐ **C) 3.0-3.5**

Medio: Hay insatisfacción

☐ **D) <3.0 o no medido**

SECCIÓN 8: COMPLIANCE REGULATORIO

8.1 — Regulatory Frameworks

Pregunta 8.1.1: ¿Ha evaluado su organización contra requerimientos NIST CSF 2.0?

- ☐ A) Sí, mapeo completo realizado; gap analysis actualizado

-

Óptimo: Visibilidad compliance NIST

-

- ☐ B) Parcialmente; algunos dominios mapeados

-

Parcial: Cobertura selectiva

-

- ☐ C) No, pero planeado <12 meses

-

En pipeline: Timeline indefinido

-

- ☐ D) No; no es prioridad

- Riesgo: NIST recomendado NIS2

Óptimo: Visibilidad compliance NIST

- ☐ **B) Parcialmente; algunos dominios mapeados**

Parcial: Cobertura selectiva

- ☐ **C) No, pero planeado <12 meses**

En pipeline: Timeline indefinido

- ☐ **D) No; no es prioridad**

Pregunta 8.1.2: ¿Está evaluando compliance para NIS2 (regulación EU octubre 2024)?

- ☐ A) Sí, assessment formal completo; gap plan con roadmap

•

Avanzado: Preparado para transposición España

•

- ☐ B) Sí, assessment inicial; roadmap en construcción

•

Implementación: En progreso

•

- ☐ C) Sí, pero evaluación superficial

•

Incompleto: Gaps no identificados

•

- ☐ D) No; no es prioridad aún

- Crítico: Compliance risk España 2026

Avanzado: Preparado para transposición España

- ☐ **B) Sí, assessment inicial; roadmap en construcción**

Implementación: En progreso

- ☐ **C) Sí, pero evaluación superficial**

Incompleto: Gaps no identificados

- ☐ **D) No; no es prioridad aún**

Pregunta 8.1.3: ¿Está su organización sujeta a DORA (Digital Operational Resilience Act — enero 2025)?

- ☐ A) Sí, sector financiero; RTO/RPO targets definidos + testing

•

Compliance: DORA active

•

- ☐ B) Sí, pero cumplimiento parcial (governance sí, testing no)

•

Parcial: Algunos requisitos pending

•

- ☐ C) No, pero proveedor ICT crítico para financiero

•

Tercero: DORA aplica indirectamente

•

- ☐ D) No aplica

- No compliance: Verificar scope

Compliance: DORA active

- ☐ **B) Sí, pero cumplimiento parcial (governance sí, testing no)**

Parcial: Algunos requisitos pending

- ☐ **C) No, pero proveedor ICT crítico para financiero**

Tercero: DORA aplica indirectamente

- ☐ **D) No aplica**

SECCIÓN 9: AUTOMATIZACIÓN & INFRAESTRUCTURA

9.1 — Policy-as-Code & Infrastructure-as-Code

Pregunta 9.1.1: ¿Implementa "Policy-as-Code" (seguridad definida mediante código ejecutable)?

- ☐ A) Sí, OPA/Conftest u equivalente; políticas en CI/CD

•

Avanzado: Enforcement automático

•

- ☐ B) Sí, parcialmente; algunas políticas automatizadas

•

Implementado: Cobertura selectiva

•

- ☐ C) Planeado; roadmap <12 meses

•

Pipeline: Timeline definido

•

- ☐ D) No; policies son manuales/documentadas

- Tradicional: Sin automatización

Avanzado: Enforcement automático

- ☐ **B) Sí, parcialmente; algunas políticas automatizadas**

Implementado: Cobertura selectiva

- ☐ **C) Planeado; roadmap <12 meses**

Pipeline: Timeline definido

- ☐ **D) No; policies son manuales/documentadas**

Pregunta 9.1.2: ¿Utiliza Infrastructure-as-Code (Terraform, CloudFormation) para despliegue?

- ☐ A) Sí, 100% infrastructure via IaC; versionado + auditable

-

Óptimo: Reproducibility maxima

-

- ☐ B) Sí, 70-90% IaC

-

Implementado: Cobertura alta

-

- ☐ C) Parcial; 30-70% IaC

-

Híbrido: Mix manual + IaC

-

- ☐ D) Minimal o no IaC

- Tradicional: Despliegue manual

Óptimo: Reproducibility maxima

- ☐ **B) Sí, 70-90% IaC**

Implementado: Cobertura alta

- ☐ **C) Parcial; 30-70% IaC**

Híbrido: Mix manual + IaC

- ☐ **D) Minimal o no IaC**

9.2 — Resilience Testing & Chaos Engineering

Pregunta 9.2.1: ¿Realiza testing de resiliencia/disaster recovery?

- ☐ A) Sí, chaos engineering + automated DR testing continuo

•

Avanzado: Validación frecuente

•

- ☐ B) Sí, manual DR testing anual

•

Implementado: Validación anual

•

- ☐ C) Ad-hoc; testing infrecuente

•

Débil: Validación insuficiente

•

- ☐ D) No; no realiza testing formal

- Crítico: RTO/RPO no validados

Avanzado: Validación frecuente

- ☐ **B) Sí, manual DR testing anual**

Implementado: Validación anual

- ☐ **C) Ad-hoc; testing infrecuente**

Débil: Validación insuficiente

- ☐ **D) No; no realiza testing formal**

Pregunta 9.2.2: ¿Cuál es su RTO (Recovery Time Objective) documentado para sistemas críticos?

- ☐ A) <4 horas (cumple DORA financiero)

•

Óptimo: RTO agresivo

•

☐ B) 4-8 horas

•

Bueno: RTO razonable

•

☐ C) 8-24 horas

•

Medio: Tolerable

•

☐ D) >24 horas o desconocido

- Crítico: RTO inaceptable

Óptimo: RTO agresivo

☐ **B) 4-8 horas**

Bueno: RTO razonable

☐ **C) 8-24 horas**

Medio: Tolerable

☐ **D) >24 horas o desconocido**

Pregunta 9.2.3: ¿Cuál es su RPO (Recovery Point Objective) documentado?

- ☐ A) <1 hora (mínima pérdida datos)

•

Óptimo: RPO muy conservador

•

☐ B) 1-4 horas

•

Bueno: RPO aceptable

•

☐ C) 4-24 horas

•

Medio: Aceptable para no-crítico

•

☐ D) >24 horas o desconocido

- Débil: Pérdida datos tolerable alta

Óptimo: RPO muy conservador

☐ **B) 1-4 horas**

Bueno: RPO aceptable

☐ **C) 4-24 horas**

Medio: Aceptable para no-crítico

☐ **D) >24 horas o desconocido**

SECCIÓN 10: INDICADOR GLOBAL MADUREZ (IGM) & CONCLUSIONES

10.1 — Snapshot Maturity Score

Pregunta 10.1.1: ¿Cuál es su auto-evaluación de madurez ciberseguridad general (1-5)?

- ☐ 1 — Ad-hoc (Inicio; procesos informales)
- ☐ 2 — Formativo (Algunos procesos; institucionalización parcial)
- ☐ 3 — Establecido (Procesos estandarizados; bien institucionalizado)
- ☐ 4 — Estratégico (Medición, optimización; cultura mejora)
- ☐ 5 — Dinámico (Innovación continua; anticipatorio)

Pregunta 10.1.2: ¿Cuál es su mayor gap de ciberseguridad actual?

- ☐ A) Gobernanza estratégica (CISO, Risk Appetite, junta alignment)
- ☐ B) Cuantificación monetaria (FAIR, ROI decisions)
- ☐ C) Threat modeling operacional (PASTA, attack scenarios)
- ☐ D) Métricas & SOC (MTTD/MTTR, SIEM, alerting)
- ☐ E) Vulnerabilities & patching (coverage, SLA)
- ☐ F) Supply chain risk (terceros, SBOM)
- ☐ G) Awareness training (phishing, ROI)
- ☐ H) Compliance regulatorio (GDPR, DORA, NIS2)
- ☐ I) Automatización (Policy-as-Code, Chaos Testing)

Pregunta 10.1.3: ¿Cuál es su top 3 prioridad de inversión ciberseguridad próximos 12 meses?

(Abierta; completar con 3 items prorizados)

CÁLCULO IGM (Índice Global Madurez)

Ver archivo "**Plantilla_IGM_y_ROI.md**" para automatizar scoring + cálculo.

Fin de Encuesta | Gracias por su participación

Para soporte: [contacto@crm-survey.es]